

数据库系统原理实验—实验十一

数据库安全性控制实验

学　　号: 23336179

姓　　名: 马福泉

专　　业: 计算机科学与技术

课 程 教 师: 赖韩江

起 始 日 期: 2025年12月11日

结 束 日 期: 2025年12月18日

实 验 地 点: B202

目录

1 实验概述 **2**
1.1 实验目的 2
1.2 实验内容 2

2 实验报告 **2**
2.1 实验1：创建登录账户和数据库用户 2
2.2 实验2：测试新用户权限 5
2.3 实验3：授予book表操作权限 6
2.4 实验4：撤销部分权限 8
2.5 实验5：创建视图并管理权限 10
2.6 实验6：创建部门限制视图 13
2.7 实验总结 15
2.7.1 困难和解决 15
2.7.2 主要收获 15

1　实验概述

1.1　实验目的

掌握数据库安全性控制。

1.2　实验内容

1. 创建SQL Server登录账户mafuquan2024（即用户名是学生本人的姓名拼音+2024，下同）、密码123456，JY数据库的用户。
2. 使用用户名mafuquan2024登录进系统中，输入 `select * from book`，是否可以运行？
3. 将JY数据库book表的操作权限（Select、update、delete、Insert）赋于数据库用户mafuquan2024。
4. 取消mafuquan2024对book表的更新与删除权限。
5. 创建一个视图，显示reader表中借阅次数>1次的读者信息，并将该视图的SELECT权限授予mafuquan2024。之后，撤销mafuquan024对该视图的所有权限。
6. 创建一个视图，在reader表中，只能检索“涉外教育系”的读者信息，将该视图的所有权限赋于数据库用户mafuquan2024。

2　实验报告

本实验围绕SQL Server数据库安全性控制，依次完成了账户创建、权限分配与回收、视图管理等操作。以下为详细过程与结果。

2.1　实验1：创建登录账户和数据库用户

步骤1.1：以管理员身份登录SQL Server Management Studio

- 使用Windows身份验证或sa账户登录服务器“FORTUNE”。
- 登录界面如图所示：



图 1: SQL Server 管理员登录界面

步骤1.2：创建SQL Server登录账户

```
USE master;
GO

IF EXISTS (SELECT 1 FROM sys.server_principals WHERE name = 'mafuquan2024')
    DROP LOGIN mafuquan2024;
GO

CREATE LOGIN mafuquan2024
    WITH PASSWORD = '123456',
    DEFAULT_DATABASE = JY,
    CHECK_EXPIRATION = OFF,
    CHECK_POLICY = OFF;
GO

SELECT
    name AS 登录名,
    type_desc AS 类型,
    default_database_name AS 默认数据库,
    create_date AS 创建日期
FROM sys.server_principals
WHERE name = 'mafuquan2024';
```

登录账户创建结果如下：



图 2: 登录账户创建结果

步骤1.3：创建数据库用户

```
USE JY;
GO

IF EXISTS (SELECT 1 FROM sys.database_principals WHERE name = 'mafuquan2024')
    DROP USER mafuquan2024;
GO

CREATE USER mafuquan2024 FOR LOGIN mafuquan2024;
GO

SELECT
    name AS 用户名,
    type_desc AS 类型,
    authentication_type_desc AS 认证类型,
    default_schema_name AS 默认架构
FROM sys.database_principals
WHERE name = 'mafuquan2024';
```

数据库用户创建结果如下：

```
10  -- 创建数据库用户并关联登录账户
11  CREATE USER mafuquan2024 FOR LOGIN mafuquan2024;
12  GO
13
14  -- 验证用户创建
15  SELECT
16      name AS 用户名,
17      type_desc AS 类型,
18      authentication_type_desc AS 认证类型,
19      default_schema_name AS 默认架构
20  FROM sys.database_principals
21  WHERE name = 'mafuquan2024';
```

93 % ✓ 未找到相关问题

结果 消息

	用户名	类型	认证类型	默认架构
1	mafuquan2024	SQL_USER	INSTANCE	dbo

图 3: 数据库用户创建结果

2.2　实验2：测试新用户权限

步骤2.1：断开当前连接，使用新账户登录

- 登录名：mafuquan2024，密码：123456
- 登录界面如图所示：



图 4: 新用户登录界面

步骤2.2：尝试查询book表

```
SELECT TOP 5 * FROM book;
```

查询结果如下：

```
1  select * from book
```

93 % ⊗ 1 ⚠ 0

消息

```
消息 229，级别 14，状态 5，第 1 行
拒绝了对对象 'book' (数据库 'JY'，架构 'dbo')的 SELECT 权限。

完成时间: 2025-12-12T10:46:52.2950802+08:00
```

图 5: 新用户查询book表权限不足

如图所示，查询book表时出现权限不足的错误，说明新用户默认没有访问book表的权限。

2.3　实验3：授予book表操作权限

步骤3.1：以管理员身份授权

```
USE JY;
GO

GRANT SELECT, INSERT, UPDATE, DELETE ON dbo.book TO mafuquan2024;
GO

SELECT
    USER_NAME(grantee_principal_id) AS 用户名,
    OBJECT_NAME(major_id) AS 对象名,
    permission_name AS 权限,
    state_desc AS 状态
FROM sys.database_permissions
WHERE USER_NAME(grantee_principal_id) = 'mafuquan2024'
    AND OBJECT_NAME(major_id) = 'book';
```

授权结果如下：

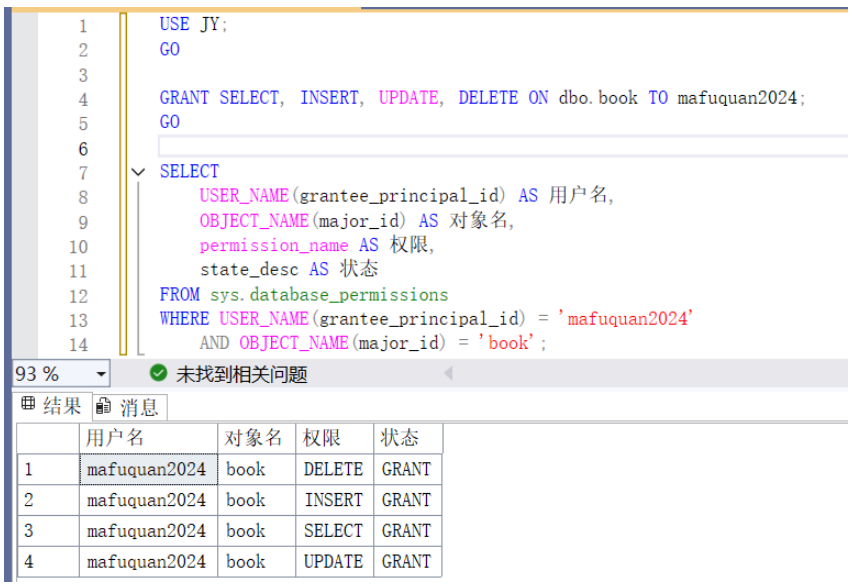


图 6: book表权限授权结果

步骤3.2：测试权限

```
USE JY;
GO

-- 权限SELECT
SELECT TOP 1 * FROM book;

-- 权限INSERT
```

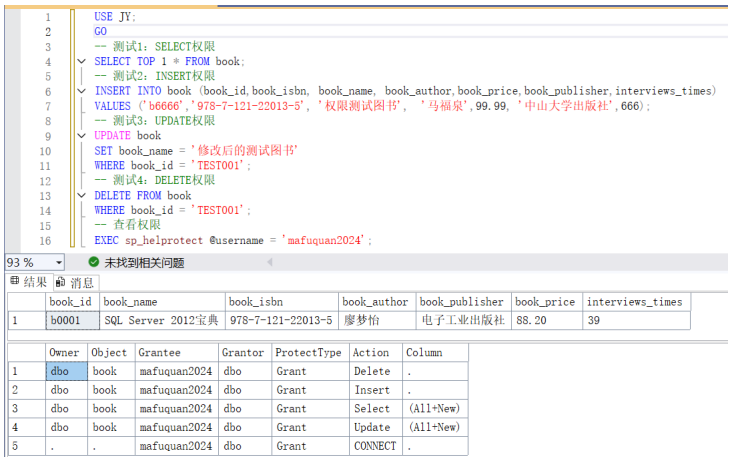
```
INSERT INTO book (book_id,book_isbn, book_name, book_author,book_price,
    book_publisher,interviews_times)
VALUES ('t0001','978-7-121-22013-5', '权限测试图书',  '马福泉',99.99, '中山大学出版
    社',666);

-- 权限UPDATE
UPDATE book
SET book_name = '修改后的测试图书'
WHERE book_id = 'TEST001';

-- 权限DELETE
DELETE FROM book
WHERE book_id = 'TEST001';

EXEC sp_helprotect @username = 'mafuquan2024';
```

测试结果如下：



```
USE JY;
GO
-- 测试1：SELECT权限
SELECT TOP 1 * FROM book;
-- 测试2：INSERT权限
INSERT INTO book (book_id,book_isbn, book_name, book_author,book_price,book_publisher,interviews_times)
VALUES ('b6666','978-7-121-22013-5', '权限测试图书',  '马福泉',99.99, '中山大学出版社',666);
-- 测试3：UPDATE权限
UPDATE book
SET book_name = '修改后的测试图书'
WHERE book_id = 'TEST001';
-- 测试4：DELETE权限
DELETE FROM book
WHERE book_id = 'TEST001';
-- 查看权限
EXEC sp_helprotect @username = 'mafuquan2024';
```

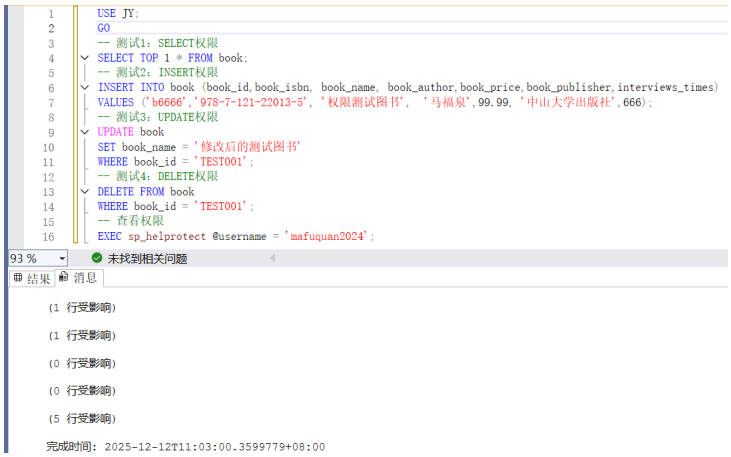
93 % 未找到相关问题

结果 消息

	book_id	book_name	book_isbn	book_author	book_publisher	book_price	interviews_times
1	b0001	SQL Server 2012宝典	978-7-121-22013-5	廖梦怡	电子工业出版社	88.20	39

	Owner	Object	Grantee	Grantor	ProtectType	Action	Column
1	dbo	book	mafuquan2024	dbo	Grant	Delete	.
2	dbo	book	mafuquan2024	dbo	Grant	Insert	.
3	dbo	book	mafuquan2024	dbo	Grant	Select	(All+New)
4	dbo	book	mafuquan2024	dbo	Grant	Update	(All+New)
5	.	.	mafuquan2024	dbo	Grant	CONNECT	.

图 7: book表操作权限测试（1）



```
USE JY;
GO
-- 测试1：SELECT权限
SELECT TOP 1 * FROM book;
-- 测试2：INSERT权限
INSERT INTO book (book_id,book_isbn, book_name, book_author,book_price,book_publisher,interviews_times)
VALUES ('b6666','978-7-121-22013-5', '权限测试图书',  '马福泉',99.99, '中山大学出版社',666);
-- 测试3：UPDATE权限
UPDATE book
SET book_name = '修改后的测试图书'
WHERE book_id = 'TEST001';
-- 测试4：DELETE权限
DELETE FROM book
WHERE book_id = 'TEST001';
-- 查看权限
EXEC sp_helprotect @username = 'mafuquan2024';
```

93 % 未找到相关问题

结果 消息

(1 行受影响)

(1 行受影响)

(0 行受影响)

(0 行受影响)

(5 行受影响)

完成时间: 2025-12-12T11:03:00.3599779+08:00

图 8: book表操作权限测试（2）

如上图所示，用户mafuquan2024成功执行了SELECT、INSERT、UPDATE和DELETE操作，说明权限授予成功。

2.4　实验4：撤销部分权限

步骤4.1：撤销UPDATE和DELETE权限

```
USE JY;
GO

REVOKE UPDATE ON dbo.book FROM mafuquan2024;
REVOKE DELETE ON dbo.book FROM mafuquan2024;
GO

SELECT
    USER_NAME(grantee_principal_id) AS 用户名,
    permission_name AS 权限,
    state_desc AS 状态
FROM sys.database_permissions
WHERE USER_NAME(grantee_principal_id) = 'mafuquan2024'
    AND OBJECT_NAME(major_id) = 'book';
```

权限撤销结果如下：

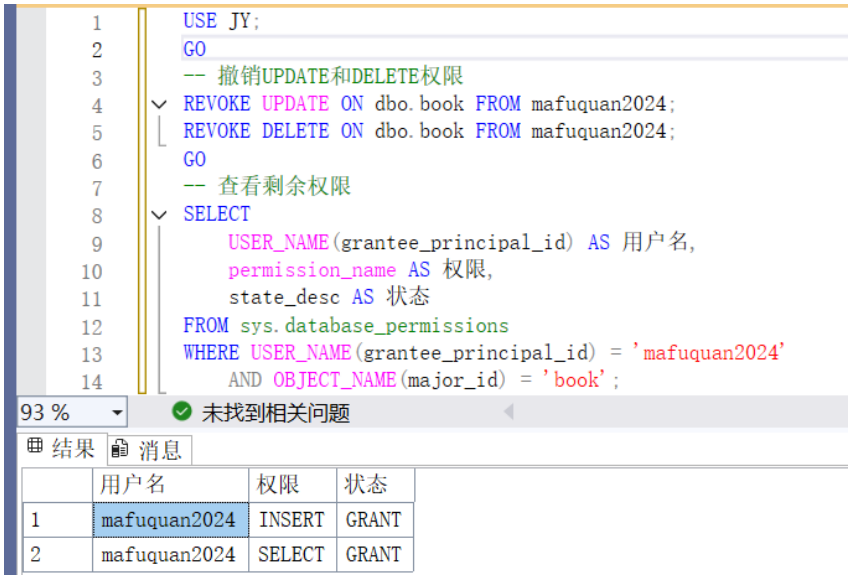


图 9: 撤销UPDATE和DELETE权限结果

步骤4.2：测试撤销效果

```
SELECT TOP 3 * FROM book;

INSERT INTO book (book_id,book_isbn, book_name, book_author,book_price,
    book_publisher,interviews_times)
VALUES ('b6668','978-7-121-22013-5', '权限测试图书2',  '马福泉',99.99, '中山大学出版
    社',667);

BEGIN TRY
    UPDATE book
    SET book_name = '尝试修改'
    WHERE book_id = 'TEST002';
```

```
BEGIN CATCH
    PRINT '失败（预期结果）UPDATE';
    PRINT ERROR_MESSAGE();
END CATCH

BEGIN TRY
    DELETE FROM book WHERE book_id = 'TEST002';
END TRY
BEGIN CATCH
    PRINT '失败（预期结果）DELETE';
    PRINT ERROR_MESSAGE();
END CATCH
```

测试结果如下：

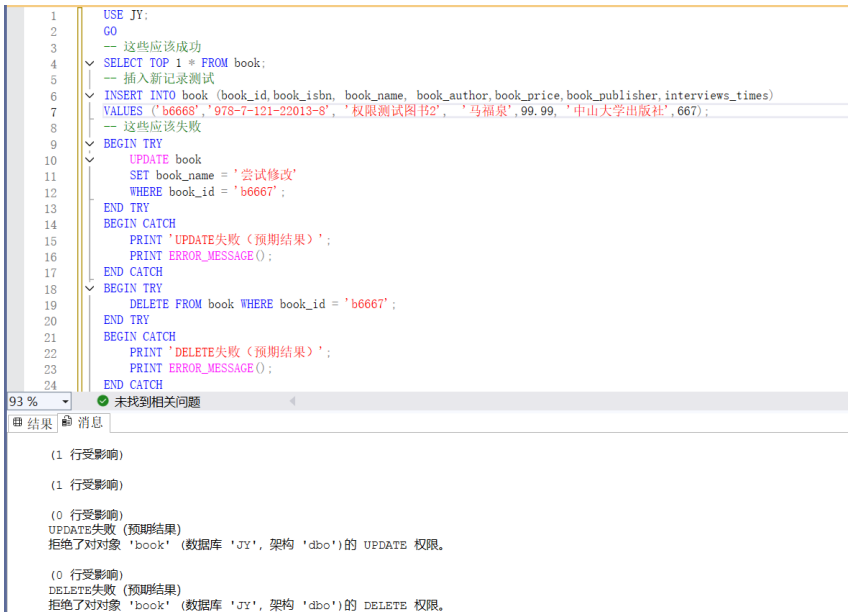


图 10: 撤销权限后操作测试结果

如上图，Select和Insert操作成功，而Update和Delete操作均失败，符合预期，说明权限撤销生效。

2.5　实验5：创建视图并管理权限

步骤5.1：创建借阅次数>1的读者视图

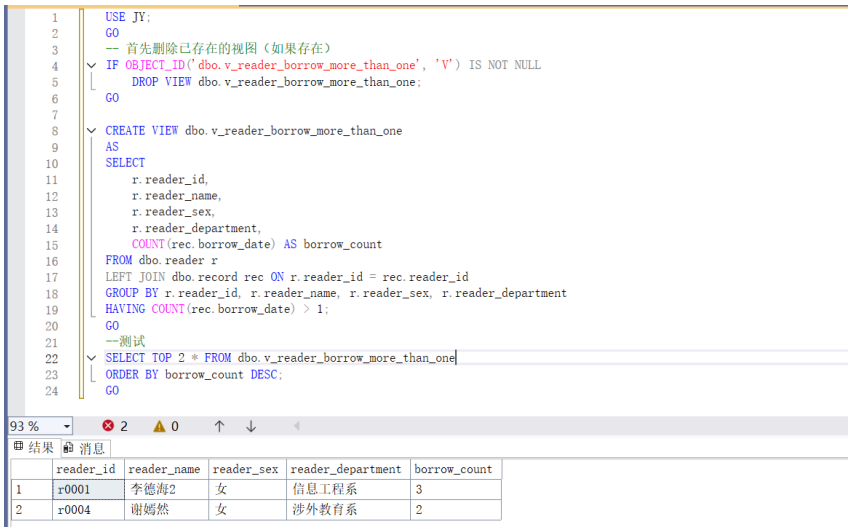
```
USE JY;
GO

CREATE VIEW dbo.v_reader_borrow_more_than_one
AS
SELECT
    r.reader_id,
    r.reader_name,
    r.reader_sex,
    r.reader_department,
```

```
    COUNT(rec.borrow_date) AS borrow_count
FROM dbo.reader r
LEFT JOIN dbo.record rec ON r.reader_id = rec.reader_id
GROUP BY r.reader_id, r.reader_name, r.reader_sex, r.reader_department
HAVING COUNT(rec.borrow_date) > 1;
GO

SELECT TOP 10 * FROM dbo.v_reader_borrow_more_than_one
ORDER BY borrow_count DESC;
```

视图创建及查询结果如下：



```
USE JY;
GO
-- 首先删除已存在的视图（如果存在）
IF OBJECT_ID('dbo.v_reader_borrow_more_than_one', 'V') IS NOT NULL
    DROP VIEW dbo.v_reader_borrow_more_than_one;
GO

CREATE VIEW dbo.v_reader_borrow_more_than_one
AS
SELECT
    r.reader_id,
    r.reader_name,
    r.reader_sex,
    r.reader_department,
    COUNT(rec.borrow_date) AS borrow_count
FROM dbo.reader r
LEFT JOIN dbo.record rec ON r.reader_id = rec.reader_id
GROUP BY r.reader_id, r.reader_name, r.reader_sex, r.reader_department
HAVING COUNT(rec.borrow_date) > 1;
GO
--测试
SELECT TOP 2 * FROM dbo.v_reader_borrow_more_than_one
ORDER BY borrow_count DESC;
GO
```

93 % ⊗ 2 ⚠ 0

结果 消息

	reader_id	reader_name	reader_sex	reader_department	borrow_count
1	r0001	李德海2	女	信息工程系	3
2	r0004	谢婧然	女	涉外教育系	2

图 11: 借阅次数大于1的读者视图及查询结果

步骤5.2：授予视图SELECT权限

```
GRANT SELECT ON dbo.v_reader_borrow_more_than_one TO mafuquan2024;
GO

SELECT
    USER_NAME(grantee_principal_id) AS 用户名,
    OBJECT_NAME(major_id) AS 对象名,
    permission_name AS 权限
FROM sys.database_permissions
WHERE USER_NAME(grantee_principal_id) = 'mafuquan2024'
    AND OBJECT_NAME(major_id) = 'v_reader_borrow_more_than_one';
```

授权结果如下：

```
-- 授予SELECT权限
GRANT SELECT ON dbo.v_reader_borrow_more_than_one TO mafuquan2024;
GO
-- 查看权限
SELECT
    USER_NAME(grantee_principal_id) AS 用户名,
    OBJECT_NAME(major_id) AS 对象名,
    permission_name AS 权限
FROM sys.database_permissions
WHERE USER_NAME(grantee_principal_id) = 'mafuquan2024'
    AND OBJECT_NAME(major_id) = 'v_reader_borrow_more_than_one';
```

93 % 2 0

结果 消息

	用户名	对象名	权限
1	mafuquan2024	v_reader_borrow_more_than_one	SELECT

图 12: 视图SELECT权限授权结果

步骤5.3：测试视图访问

```
USE JY;
GO
SELECT TOP 10 * FROM v_reader_borrow_more_than_one
ORDER BY borrow_count DESC;
```

查询结果如下：

```
USE JY;
GO
-- 测试视图查询
SELECT TOP 10 * FROM v_reader_borrow_more_than_one
ORDER BY borrow_count DESC;
GO
```

93 % 2 0

结果 消息

	reader_id	reader_name	reader_sex	reader_department	borrow_count
1	r0001	李德海2	女	信息工程系	3
2	r0004	谢嫣然	女	涉外教育系	2

图 13: 新用户访问视图查询结果

如上图所示，用户mafuquan2024成功查询了视图，说明SELECT权限授予成功。

步骤5.4：撤销视图权限

```
USE JY;
GO

REVOKE SELECT ON dbo.v_reader_borrow_more_than_one FROM mafuquan2024;
GO

IF NOT EXISTS (
    SELECT 1
    FROM sys.database_permissions
    WHERE USER_NAME(grantee_principal_id) = 'mafuquan2024'
        AND OBJECT_NAME(major_id) = 'v_reader_borrow_more_than_one'
)
    PRINT '权限已成功撤销';
```

权限撤销结果如下：

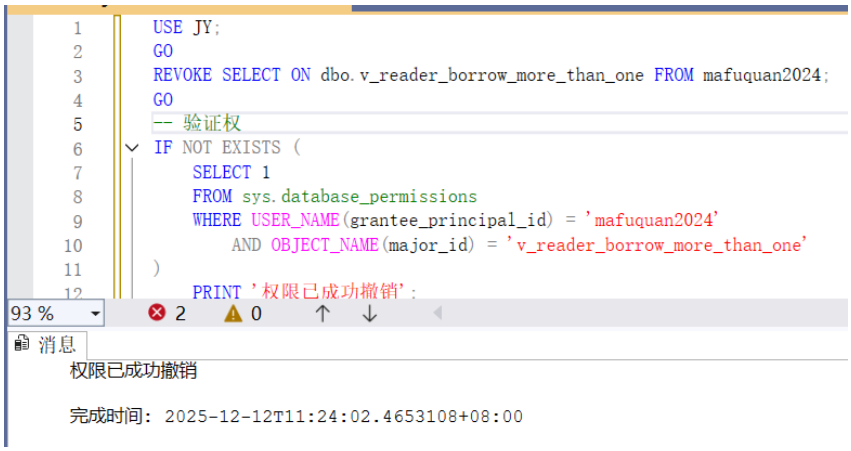


图 14: 撤销视图权限结果

2.6　实验6：创建部门限制视图

步骤6.1：检查reader表数据

```
SELECT DISTINCT reader_department, COUNT(*) as 人数
FROM reader
GROUP BY reader_department
ORDER BY reader_department;
```

步骤6.2：创建“涉外教育系”读者视图

```
IF OBJECT_ID('dbo.v_reader_foreign_edu', 'V') IS NOT NULL
    DROP VIEW dbo.v_reader_foreign_edu;
GO

CREATE VIEW dbo.v_reader_foreign_edu
AS
SELECT
    reader_id,
    reader_name,
    reader_sex,
    reader_department
FROM dbo.reader
WHERE reader_department = N'涉外教育系';
GO

SELECT * FROM dbo.v_reader_foreign_edu;
```

视图创建及查询结果如下：

```
PRINT '创建"涉外教育系"读者视图...';
IF OBJECT_ID('dbo.v_reader_foreign_edu', 'V') IS NOT NULL
    DROP VIEW dbo.v_reader_foreign_edu;
GO

CREATE VIEW dbo.v_reader_foreign_edu
AS
SELECT
    reader_id,          -- char(8)
    reader_name,        -- nvarchar(50)
    reader_sex,         -- char(2)
    reader_department -- nvarchar(60)
FROM dbo.reader
WHERE reader_department = N'涉外教育系';  -- 使用N前缀，因为列是nvarchar
GO

SELECT * FROM dbo.v_reader_foreign_edu;
GO
```

视图 JY.dbo.v_reader_foreign_edu

93 % 1 0

结果 消息

	reader_id	reader_name	reader_sex	reader_department
1	r0004	谢嫣然	女	涉外教育系
2	r0005	陈静玉	女	涉外教育系

图 15: “涉外教育系”读者视图及查询结果

步骤6.3：查看权限

```
SELECT
    USER_NAME(grantee_principal_id) AS 用户名,
    permission_name AS 权限,
    state_desc AS 状态
FROM sys.database_permissions
WHERE USER_NAME(grantee_principal_id) = 'mafuquan2024'
    AND OBJECT_NAME(major_id) = 'v_reader_foreign_edu';
```

权限结果如下：

```
GRANT SELECT, INSERT, UPDATE, DELETE ON dbo.v_reader_foreign_edu TO mafuquan2024;
GO
-- 查看授予的权限
SELECT
    USER_NAME(grantee_principal_id) AS 用户名,
    permission_name AS 权限,
    state_desc AS 状态
FROM sys.database_permissions
WHERE USER_NAME(grantee_principal_id) = 'mafuquan2024'
    AND OBJECT_NAME(major_id) = 'v_reader_foreign_edu';
GO
```

93 % 1 0

结果 消息

	用户名	权限	状态
1	mafuquan2024	DELETE	GRANT
2	mafuquan2024	INSERT	GRANT
3	mafuquan2024	SELECT	GRANT
4	mafuquan2024	UPDATE	GRANT

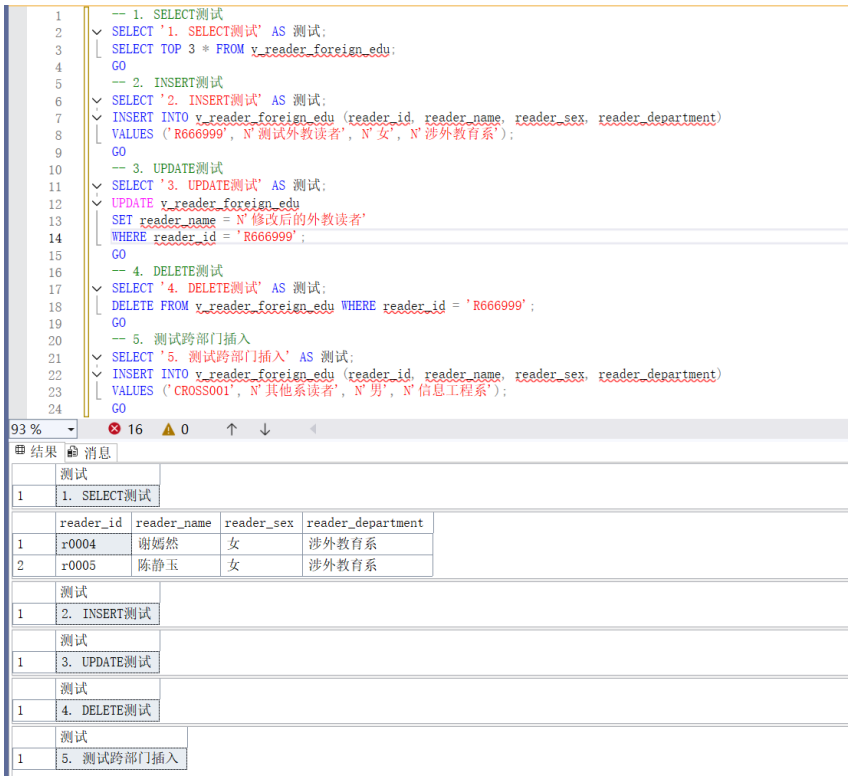
图 16: “涉外教育系”视图权限结果

步骤6.4：测试视图所有权限

```
-- 1. 测试SELECT
SELECT TOP 3 * FROM v_reader_foreign_edu;
GO
-- 2. 测试INSERT
```

```
INSERT INTO v_reader_foreign_edu (reader_id, reader_name, reader_sex,
    reader_department)
VALUES ('R666999', N'测试外教读者', N'女', N'涉外教育系');
GO
-- 3. 测试UPDATE
UPDATE v_reader_foreign_edu
SET reader_name = N'修改后的外教读者'
WHERE reader_id = 'R666999';
GO
-- 4. 测试DELETE
DELETE FROM v_reader_foreign_edu WHERE reader_id = 'R666999';
GO
-- 5. 测试跨部门插入
INSERT INTO v_reader_foreign_edu (reader_id, reader_name, reader_sex,
    reader_department)
VALUES ('CROSS001', N'其他系读者', N'男', N'信息工程系');
GO
```

权限及操作结果如下：



```
-- 1. SELECT测试
SELECT '1. SELECT测试' AS 测试;
SELECT TOP 3 * FROM v_reader_foreign_edu;
GO
-- 2. INSERT测试
SELECT '2. INSERT测试' AS 测试;
INSERT INTO v_reader_foreign_edu (reader_id, reader_name, reader_sex, reader_department)
VALUES ('R666999', N'测试外教读者', N'女', N'涉外教育系');
GO
-- 3. UPDATE测试
SELECT '3. UPDATE测试' AS 测试;
UPDATE v_reader_foreign_edu
SET reader_name = N'修改后的外教读者'
WHERE reader_id = 'R666999';
GO
-- 4. DELETE测试
SELECT '4. DELETE测试' AS 测试;
DELETE FROM v_reader_foreign_edu WHERE reader_id = 'R666999';
GO
-- 5. 测试跨部门插入
SELECT '5. 测试跨部门插入' AS 测试;
INSERT INTO v_reader_foreign_edu (reader_id, reader_name, reader_sex, reader_department)
VALUES ('CROSS001', N'其他系读者', N'男', N'信息工程系');
GO
```

93 % ⊗ 16 ⚠ 0

结果 消息

	测试
1	1. SELECT测试

	reader_id	reader_name	reader_sex	reader_department
1	r0004	谢婧然	女	涉外教育系
2	r0005	陈静玉	女	涉外教育系

	测试
1	2. INSERT测试

	测试
1	3. UPDATE测试

	测试
1	4. DELETE测试

	测试
1	5. 测试跨部门插入

图 17: “涉外教育系”视图权限及操作测试结果

如上图所示，用户mafuquan2024成功执行了SELECT、INSERT、UPDATE和DELETE操作，且无法插入非“涉外教育系”的读者数据，说明视图权限设置正确。

2.7 实验总结

2.7.1 困难和解决

在实验过程中遇到如下主要困难及解决办法：

困难：连接到服务器时出现证书链错误

- **问题描述：** 在使用SQL Server Management Studio连接服务器“FORTUNE”时，出现如下报错：

  > 标题: 连接到服务器无法连接到 FORTUNE。其他信息: A connection was successfully established with the server, but then an error occurred during the login process. (provider: SSL Provider, error: 0 - 证书链是由不受信任的颁发机构颁发的。) (Microsoft SQL Server，错误: -2146893019) 证书链是由不受信任的颁发机构颁发的。

- **解决方案：** 在登录窗口的“其他连接参数”选项卡中，添加如下参数：

  ```
  TrustServerCertificate=True
  ```

  这样即可跳过证书信任校验，顺利连接到服务器。

2.7.2 主要收获

通过本次实验，初步理解了SQL Server数据库的安全性控制机制，掌握了以下技能：

- 能够创建SQL Server登录账户和数据库用户，理解两者的区别与联系；
- 熟悉了数据库对象（如表、视图）的权限分配与回收操作；
- 熟悉了常见权限错误的排查与验证流程。